Plan de escalabilidad, datos y cumplimiento

LICITANK Radar + Negocios como servicio para más de 100 empresas

22 de octubre de 2026 · Versión 2 (reemplaza al plan anterior) · Documento de trabajo, no es asesoría legal

Aviso importante. Este documento ordena lo técnico y lista lo legal que hay que resolver. Las normas citadas se verificaron en fuentes secundarias (estudios de abogados y guías), no en el texto oficial de la Biblioteca del Congreso Nacional. Antes de firmar contratos con clientes, **un abogado especialista en protección de datos y contratos tecnológicos debe revisar y validar todo lo legal**. Es la primera contratación que recomendamos.

1. Resumen ejecutivo

1. **Base de datos:** no se crea una base por cliente. Se usa **una sola base compartida, con el cliente como parte de cada fila** y varias capas de protección. Se deja preparada la posibilidad de mover a un cliente grande a una base propia cuando lo pida o lo necesite («aislamiento bajo demanda»).
2. **Ley de datos personales (Ley 21.719):** entra en vigencia el **1 de diciembre de 2026** según su texto. Hay un proyecto para postergarla un año (aprobado «en general» por la comisión del Senado el 19 de octubre, aún no es ley). Planificamos con diciembre de 2026 como fecha, porque las obligaciones de fondo no cambian aunque se aplace. Las multas llegan a **20.000 UTM** por infracción gravísima, con recargos por reincidencia.
3. **Riesgo de negocio nº 1, fuera de lo legal:** las condiciones de la API de Mercado Público indican **un ticket por persona**, con un límite de **10.000 consultas diarias no modificable**, y ChileCompra puede suspender el acceso sin derecho adquirido. No regulan expresamente el uso comercial ni la reventa. Medimos que **ICA sola ya usa en promedio unas 8.600 consultas al día** (máximo 9.460), es decir, casi toda la cuota. Hay que pedir una respuesta **por escrito** a ChileCompra antes de vender y rediseñar el radar para que cada cliente nuevo cueste casi cero consultas (secciones 6 y 7).
4. **Plazo:** hasta el piloto con clientes reales, unas **14 a 18 semanas**. La parte técnica de multi-cliente (7 a 10 semanas) se hace en paralelo con lo legal, la seguridad y las pruebas.
5. **Regla de oro:** no se vende al primer cliente sin cumplir las «puertas de salida» de la sección 10.

2. Arquitectura de datos: cómo lo hacemos y por qué

Las tres opciones

	A. Una base por cliente	B. Un esquema por cliente	C. Una base compartida, con cliente_id (recomendada)
Cómo es	100 clientes = 100 bases con las 136 tablas cada una.	Una base con 100 grupos de tablas.	Una base y 136 tablas. Cada fila privada lleva el cliente al que pertenece.
Aislamiento	El más fuerte (físico).	Fuerte.	Lógico: depende de que el código filtre siempre. Se refuerza con capas (abajo).
Operación	Cada cambio de estructura se corre 100 veces; 100 conexiones y respaldos que vigilar; altas de cliente más lentas.	Miles de tablas (13.600 con 100 clientes); migraciones y respaldos pesados.	Una migración, un respaldo, una conexión. Alta de cliente en segundos.
Costo	Crece con cada cliente.	Medio.	El más bajo y predecible.

Escala	Hasta decenas; después es inmanejable para un equipo pequeño.	Similar.	Cientos o miles de clientes pequeños (2 usuarios cada uno) en una base.
Eliminar o exportar un cliente	Trivial (la base completa).	Fácil.	Requiere borrar o exportar por cliente_id; se programa y se prueba desde el inicio.
Riesgo principal	Costo y errores de operación.	Complejidad.	Un filtro olvidado puede filtrar datos. **Es el que más hay que controlar.**

Por qué C. Cada cliente tiene solo 2 usuarios y pocos datos propios. Lo pesado (las licitaciones de Mercado Público) es público y se comparte una sola vez. Con A o B pagaríamos complejidad y costo por cada cliente para resolver un problema que C resuelve con disciplina y pruebas.

Capas de protección para que el modelo C sea seguro

Capa	Qué es	Estado
1	**El cliente sale de la sesión**, nunca del navegador (no se acepta como parámetro, cuerpo ni encabezado).	Hecho (paso A, probado).
2	**Capa única de acceso a datos** que obliga a incluir el cliente en toda consulta a tablas privadas y rechaza las que no lo hagan.	Por construir (Fase 1).
3	**Integridad en la propia base:** llaves únicas y relaciones que incluyen el cliente, para que un registro no pueda apuntar a datos de otro cliente.	Por construir (Fase 1).
4	**Auditoría automática del código:** un script que falla si aparece una consulta a una tabla privada sin filtro de cliente.	Por construir (Fase 1).
5	**Pruebas de aislamiento automáticas** con clientes de prueba y datos marcados; se corren antes de cada despliegue.	Por construir (Fase 3).
6	**Mínimo privilegio:** la aplicación usa un usuario de base de datos con los permisos justos, nunca el de administrador.	Por revisar.
7	**Bitácora de accesos** a datos de cliente y alertas por actividad anómala.	Parcial (existe bitácora de actividad).

Aislamiento bajo demanda. La tabla de clientes puede indicar en el futuro a qué base pertenece cada uno. Si un cliente grande exige una base propia, se mueve ese cliente sin rediseñar el sistema.

Datos compartidos y datos privados

- **Compartido (sin cliente):** licitaciones, adjudicaciones, aperturas y ofertas de Mercado Público. Se descargan una sola vez.
- **Privado (con cliente):** usuarios, negocios, palabras clave, alertas, etiquetas, favoritos, descartadas, comentarios, historial, actividad, reportes de error, documentos subidos y el registro de uso de IA.
- **Interno, no se vende:** Compras, Auditor, Anexos, Costeo, Viabilidad IA, chats y Entregas, bloqueados por cliente.

Ruta de crecimiento de la infraestructura

Etapa	Infraestructura	Se pasa a la siguiente cuando
1. Lanzamiento hasta ~50 clientes	Servidor actual (4 vCPU, 12 GB) o uno dedicado a la base. **Registro binario activado** para recuperar a un minuto exacto; respaldos cifrados fuera del servidor; entorno de pruebas separado.	La prueba de carga (Fase 3) o el monitoreo muestran CPU sostenida alta o consultas lentas.
2. Crecimiento ~50 a 300	Base en su propio servidor; réplica de lectura para informes; la aplicación en 2 instancias con balanceo; trabajos programados en un proceso aparte.	La base única llega a su límite medido, o un cliente exige aislamiento propio.
3. Escala 300 o más	Reparto de clientes en varias bases (el directorio de clientes decide cuál); clientes grandes con base dedicada.	—

Las cifras de capacidad se fijan con una prueba de carga que simule 100 clientes (Fase 3); hoy no hay una medición que permita prometer un número.

---

3. Cumplimiento legal en Chile

Quién es LICITANK ante la ley de datos

- **Responsable** de los datos de las cuentas de sus clientes (nombre, correo, teléfono, registros de acceso): decide para qué se usan.
- **Encargado de tratamiento** de lo que cada cliente carga (negocios, comentarios, documentos): trata datos por cuenta del cliente y según sus instrucciones. Si se excede de ese encargo, pasa a ser responsable. Esto exige un **contrato de encargo** con contenido mínimo.

Qué exige la Ley 21.719 y qué hay que tener

Exigencia	En qué consiste	Qué hacemos
Transparencia art. 14 ter	Política publicada con finalidades, destinatarios, plazos de conservación y canal para ejercer derechos.	Política de privacidad y canal de privacidad; texto redactado por el abogado.
Licitud arts. 12 y 13	Consentimiento u otra base (contrato, obligación legal, interés legítimo). Hay que poder **demostrar** la base usada.	Registro de qué base se usa para cada tratamiento y aceptación de términos con fecha y versión.
Derechos de las personas arts. 4 a 11	Acceso, rectificación, supresión, oposición, portabilidad y bloqueo. Respuesta en **30 días corridos** (prorrogable una vez); bloqueo temporal en 2 días hábiles.	Procedimiento y herramientas en el producto: exportar y borrar los datos de una persona o de un cliente.
Seguridad art. 14 quinquies	Medidas proporcionales al riesgo. **Responsabilidad demostrable**: no basta cumplir, hay que acreditarlo.	Sección 5 y documentación de las medidas.
Privacidad desde el diseño art. 14 quáter	Tratar solo los datos necesarios, con configuración por defecto protectora.	Para clientes no pedir RUT ni foto de usuario; revisar cada campo de la tabla de usuarios.

Contrato con encargados art. 15 bis	Contrato con contenido mínimo con quien trata datos por cuenta de otro.	(a) Contrato de encargo con cada cliente. (b) Contratos con nuestros proveedores (sección 4).
Brechas de seguridad art. 14 sexies	Reportar a la Agencia sin demora indebida si hay riesgo para las personas (varias guías mencionan 72 horas; **verificar el plazo exacto**). Avisar también a los afectados en ciertos casos. Ocultarla deliberadamente es infracción **gravísima**.	Procedimiento de incidentes, registro de brechas y plantilla de aviso a clientes.
Transferencias internacionales arts. 27 y 28	Enviar datos fuera de Chile exige país adecuado o garantías (por ejemplo, cláusulas contractuales).	Inventario de proveedores en el extranjero y garantías contractuales (sección 4).
Evaluación de impacto art. 15 ter	Obligatoria en tratamientos de alto riesgo (datos sensibles, perfilamiento).	Hoy no hay datos sensibles. Revisar si algún módulo de IA perfila personas.
Modelo de prevención y delegado arts. 48 a 51	Voluntario, pero toda empresa debe prevenir infracciones. **Certificarlo es atenuante expresa**.	Designar un responsable de privacidad (puede ser el dueño) y documentar el modelo.

Multas y consecuencias

Infracción	Máximo por infracción	Ejemplos
Leve	5.000 UTM	Responder fuera de plazo o de forma incompleta a una persona.
Grave	10.000 UTM	Obstaculizar el ejercicio de derechos.
Gravísima	20.000 UTM	Tratamiento fraudulento; ocultar deliberadamente una brecha.

Reincidencia (dos o más sanciones en 30 meses): la multa puede triplicarse y, para empresas que no son de menor tamaño, llegar al 2 % o 4 % de los ingresos anuales; las fuentes difieren en los topes y hay que confirmarlos. Hay un recargo del 50 % si no se corrigen las causas en 60 días, un registro público de sanciones por 5 años y posible suspensión de operaciones de tratamiento. Las pymes no están exentas; durante el primer año la Agencia puede aplicar amonestación escrita en lugar de multa.

Otras normas a revisar con el abogado

Norma o tema	Por qué importa
Ley 19.628 (vigente hasta que rija la 21.719)	Es la que aplica hoy. El plan cumple desde ya el estándar de la ley nueva.
Ley 21.663 (Marco de Ciberseguridad)	Impone reporte de incidentes al CSIRT Nacional a los servicios esenciales y a los operadores de importancia vital. Un proveedor de software no parece estar obligado por sí mismo, pero la Agencia puede calificar a privados como operadores de importancia vital, y los clientes grandes pueden exigir estas cláusulas por contrato. **Confirmar con el abogado.**
Ley 21.459 (delitos informáticos)	Marco penal por acceso ilícito y similares. Respalda tener registros y controles de acceso.
Ley del consumidor (19.496)	Si los clientes son micro o pequeñas empresas, puede haber reglas sobre contratos de adhesión y cláusulas abusivas. **Validar el alcance.**
Contratos y firma electrónica	Aceptación en línea de términos con evidencia (fecha, versión, usuario, IP).
Tributario (SII)	Emisión de facturas electrónicas, IVA por servicios y el tratamiento contable de las suscripciones. Lo ve el contador.

Propiedad intelectual y marca	Registrar la marca LICITANK; cláusulas de propiedad del software y de los datos de cada cliente.

4. Mapa de datos personales y proveedores

Qué datos personales guarda hoy el sistema (revisión del código)

Dato	Dónde	Para qué	Decisión propuesta
Nombre, correo, teléfono, RUT, cargo, área, foto de cada usuario	Tabla de usuarios	Operar la cuenta	Para clientes pedir solo nombre y correo; teléfono, RUT y foto, opcionales o eliminados. Definir retención al término del contrato.
Correo e IP de intentos de acceso	Registro de intentos	Seguridad (bloqueo por fuerza bruta)	Purga automática, por ejemplo a los 90 días.
Acciones de cada usuario	Bitácora y historial	Trazabilidad y soporte	Conservar 12 a 24 meses; informarlo en la política.
Notas, comentarios y documentos del cliente	Negocios y almacenamiento de archivos	El servicio	Datos del cliente: nosotros somos encargados. Devolución y borrado al terminar (plazo en el contrato).
Reportes de error con adjuntos	Reportes de error	Soporte	Pueden contener datos de terceros: retención corta y acceso restringido.
Datos públicos de Mercado Público	Cachés de licitaciones	El radar	Fuente pública: citar la fuente y confirmar con el abogado el tratamiento de personas naturales.
Respaldos de todo lo anterior	Servidor de respaldo (Bluehost, EE. UU.)	Continuidad	Cifrarlos y revisar el plazo de retención (hoy 7 días); es una transferencia internacional.

Cookies y almacenamiento del navegador

- **Una sola cookie:** la sesión (*licitapyme_session*), de tipo HttpOnly, necesaria para entrar. No hay cookies de publicidad ni de analítica, ni scripts de terceros de seguimiento, y las tipografías se sirven desde el propio sitio.
- **Almacenamiento local:** solo preferencias de interfaz (tema de color, pestaña elegida, una ayuda ya vista). Revisar que nunca guarde datos personales.
- **Consecuencia:** con solo cookies estrictamente necesarias no hace falta un banner de consentimiento, pero **sí hay que describirlas en una política de cookies** dentro de la política de privacidad. Si más adelante se agrega analítica o publicidad, pasa a requerirse consentimiento previo y un banner con opción de rechazar.

Proveedores que tratan datos (subencargados)

Proveedor	Para qué	Ubicación y cuidado
V2Networks	Servidor y base de datos	Chile. Sin transferencia internacional.
Cloudflare	Túnel de acceso y almacenamiento de archivos (R2)	Fuera de Chile. Contrato de tratamiento y cláusulas estándar.
Bluehost	Respaldo nocturno	EE. UU. Cifrar antes de enviar; evaluar un proveedor mejor.
Proveedor de correo (por elegir)	Alertas y recuperación de contraseña	El servicio actual no entrega. Elegir uno con contrato de tratamiento.

Google (Gemini), DeepSeek, Z.AI, Kimi, OCR.space	Análisis con IA y lectura de documentos	**Fuera de Chile, algunos en Asia.** Quedan **fuera del plan base**. Si un cliente contrata IA: aviso expreso, aceptación y garantías contractuales.
Upstash y Obuma	Memoria rápida y facturación interna	Confirmar si tratan datos de clientes. Obuma es de uso interno.

5. Seguridad que hay que tener antes de vender

Área	Qué se hace	Hoy
Acceso	Contraseñas con bcrypt, bloqueo por intentos, **doble factor para administradores**, sesiones más cortas para clientes que los 7 días actuales, cierre de sesión al suspender.	Parcial: hay bcrypt y bloqueo; falta el doble factor.
Datos en tránsito y en reposo	HTTPS en todo; discos del servidor cifrados; archivos y respaldos cifrados; campos sensibles protegidos.	HTTPS sí; el cifrado de disco y de respaldos, por verificar.
Respaldos y recuperación	Registro binario activado para recuperar a un minuto exacto; respaldos cifrados, en otro lugar, con **prueba de restauración** trimestral; metas de recuperación escritas.	Hoy el registro binario está apagado y no hay prueba de restauración registrada.
Secretos y accesos	Rotar los secretos pendientes (CRON_SECRET, claves de archivos, certificados); un usuario de base de datos por función, sin administrador.	Rotación pendiente. **Desconectar los dos proyectos de Vercel** que aún despliegan contra el servidor antiguo.
Vulnerabilidades	Actualizar dependencias y Node (el aviso de Node 20 exige 22 desde enero de 2027); escaneo automático; **prueba de penetración externa** antes del piloto.	Pendiente.
Registro y detección	Bitácora de accesos y acciones sensibles; alertas por actividad anómala; monitoreo de disponibilidad y página de estado.	Parcial.
Entornos	Producción, pruebas y desarrollo separados; nunca datos reales de clientes en desarrollo.	En curso: base de pruebas en el servidor.
Incidentes	Procedimiento escrito: detectar, contener, evaluar, notificar a la Agencia y a los clientes, aprender. Ensayo anual.	Por redactar.

6. Riesgo de Mercado Público (la fuente de todo el radar)

Hallazgo de las condiciones de la API de ChileCompra. (1) Se entrega **un único ticket por persona**, asociado a nombre y RUT reales. (2) Cada ticket tiene un límite de **10.000 solicitudes diarias, no modificable**, y está prohibido eludirlo. (3) El acceso se monitorea por dirección IP. (4) El servicio es voluntario, **«no genera derechos adquiridos»** y ChileCompra puede modificarlo, suspenderlo o bloquearlo. (5) Quien publique datos debe **indicar que la fuente es la Dirección ChileCompra**. (6) **No regula expresamente el uso comercial, la reventa ni la redistribución.** (7) Está en marcha un nuevo portal de API que diferenciará a «integradores autenticados».

Consumo real medido (22 de octubre de 2026, últimos 30 días). Promedio de **8.644 consultas al día**, máximo **9.460**, sobre un límite de 10.000. El gobernador interno del sistema se detiene en el 92 % (9.200). **No queda margen para clientes** si el radar de cada uno hiciera sus propias consultas. Un caso real: el 15 de septiembre el ticket agotó su cuota y las consultas empezaron a fallar. *Nota: el límite de «1.000 consultas diarias» que figura en el código es el de Obuma (por endpoint), no el de Mercado Público.*

Qué significa para el negocio: todo el radar depende de un ticket personal y de un servicio que puede cambiar sin aviso. Es el punto único de falla del producto.

- **Pedir por escrito a ChileCompra** (formulario de sugerencias, respuesta en hasta 3 días hábiles) si está permitido ofrecer a terceros un servicio que muestra y organiza estos datos, y qué cuota corresponde a un integrador. Guardar la respuesta como parte del respaldo legal.
- **Ticket de la empresa:** quién lo solicita y a nombre de quién; evitar que dependa de una persona que se va.
- **Radar compartido con caché (sección 7):** el consumo no puede crecer con el número de clientes. Como ICA ya usa casi toda la cuota, primero se reduce su consumo y recién después se suman clientes.
- **Medición diaria del consumo** con alerta al 70 % y tope duro; consultas masivas entre las 22:00 y las 07:00, como recomiendan.
- **Mostrar siempre la fuente** («Fuente: Dirección ChileCompra») en la plataforma y en los contratos.
- **Plan B:** si cambian las condiciones, el contrato debe permitir ajustar el servicio sin incumplir.
- **No repartir la carga rotando tickets de distintas personas sin autorización:** las condiciones dicen que no se debe «exceder ni eludir» el límite. Hay que pedir a ChileCompra un acceso formal de integrador antes de usar más de un ticket.

---

7. Consumo de IA y de Mercado Público: cómo escala y cómo se controla

La decisión de base compartida es la que hace posible controlar el gasto: lo caro (leer las bases con IA y consultar a Mercado Público) se hace **una sola vez por licitación** y se reutiliza para todos los clientes. Con una base por cliente, cada cliente repetiría ese trabajo y el costo se multiplicaría por el número de clientes.

	Una base por cliente	Base compartida (recomendada)
Consultas a Mercado Público	Cada cliente consultaría lo mismo. Con 100 clientes, 100 veces la carga sobre un ticket que ya está casi al límite. Inviable.	Se baja una vez el universo diario de licitaciones y los detalles se guardan en una caché común. Cada cliente filtra por sus palabras clave dentro de nuestra base, sin consultar a Mercado Público.
Gasto de IA	Cada cliente pagaría de nuevo la lectura de la misma licitación.	La lectura de una licitación se hace una vez y se reutiliza. El costo crece con las licitaciones distintas, no con los clientes.

Qué gasta hoy el sistema (medido en la base real)

Concepto	Valor medido	Qué implica
Consultas a Mercado Público por día	8.644 en promedio; máx. 9.460	Casi toda la cuota de 10.000 está usada por ICA. Primero hay que reducir el consumo propio.
Gasto de IA en los últimos 30 días	unos USD 92 (≈ 5.300 llamadas)	Es el gasto de un solo cliente (ICA).
Reparto del gasto de IA	Viabilidad 57 % (USD 52); Auditor 34 % (USD 31); Consultas 7 %; el resto menos del 2 %	Viabilidad y Auditor concentran el gasto; ninguno entra en el plan base.

Costo medio de IA por licitación	USD 0,27	Permite fijar un cupo mensual por cliente y un precio del módulo.
Viabilidades ya calculadas	1.920	Reutilizables entre clientes si el análisis no depende del perfil de cada empresa.

Si 100 clientes gastaran como ICA y cada uno repitiera el trabajo, el gasto de IA sería del orden de USD 9.000 al mes (92 × 100). Con la lectura compartida es una fracción de eso. La cifra exacta se calcula con la prueba de carga.

Cómo se controla el gasto

#	Medida	Detalle
1	**Radar por «universo diario».** Se baja una vez la lista completa de licitaciones publicadas y cada cliente la filtra con sus palabras clave dentro de nuestra base.	El costo sobre Mercado Público deja de depender del número de clientes. Debe validarse con una medición antes de prometerlo.
2	**Reducir el consumo propio de ICA** antes de sumar clientes (por ejemplo, la frecuencia de los trabajos de estados, postuladas y aperturas).	Primero medir qué trabajo gasta cuánto: el contador actual solo suma el total del día.
3	**Medir por cliente y por origen.** Registrar quién y qué proceso hace cada consulta a Mercado Público y cada llamada de IA.	Agregar el cliente a la tabla de uso de IA y crear un contador de consultas por cliente.
4	**Cupos.** Cupo mensual de IA por cliente (hoy en cero en el plan base) y tope diario de consultas manuales a Mercado Público.	Al llegar al cupo, el sistema avisa y se ofrece ampliar el plan; no se corta en silencio.
5	**Alertas de gasto.** Aviso al 70 % de la cuota diaria de Mercado Público y de un presupuesto mensual de IA.	El gobernador actual al 92 % pasa a ser el último recurso.
6	**IA fuera del plan base.** Se vende como módulo aparte con cupo, aviso de proveedores en el extranjero y su costo trasladado al precio.	Evita que cada nuevo cliente aumente el gasto sin ingreso asociado.

Lo que hay que resolver antes de vender IA a otros clientes. La viabilidad actual está afinada para el negocio de ICA (ferretería y equipamiento). Para otros rubros se separa en dos capas: la **lectura de las bases**, que se hace una vez y se comparte, y la **evaluación según el perfil de cada empresa**, que se calcula por cliente y es mucho más barata. Es un trabajo de producto aparte, no parte del lanzamiento del plan base.

---

8. Documentos legales y de operación necesarios

#	Documento	Contenido clave	Quién
1	Contrato de servicio (SaaS) y términos y condiciones	Alcance, plan, precio, vigencia, término, propiedad de datos y software, límites de responsabilidad, la IA no garantiza resultados, dependencia de Mercado Público, cambios del servicio.	Abogado
2	Contrato de encargo de tratamiento de datos (DPA)	Contenido mínimo del art. 15 bis: instrucciones, confidencialidad, seguridad, subencargados, asistencia en derechos, brechas, devolución y borrado.	Abogado
3	Política de privacidad y de cookies	Finalidades, bases, destinatarios, plazos, derechos, canal de contacto, cookies y almacenamiento.	Abogado
4	Acuerdo de nivel de servicio y política de soporte	Disponibilidad objetivo, horarios, tiempos de respuesta por tipo de ticket, exclusiones, mantenciones.	Dueño y abogado

5	Política de uso aceptable	Qué no se puede hacer (reventa de datos, uso abusivo, automatizaciones que excedan límites).	Abogado
6	Registro de actividades de tratamiento y de proveedores	Inventario vivo de datos, bases de licitud, plazos y subencargados (sección 4).	Desarrollo y responsable de privacidad
7	Procedimiento de derechos de las personas	Cómo se reciben, verifican y responden en 30 días; plantillas.	Responsable de privacidad
8	Plan de respuesta a incidentes y registro de brechas	Roles, plazos de notificación, plantillas para la Agencia y los clientes.	Desarrollo y abogado
9	Política de retención y borrado	Cuánto se guarda cada dato y cómo se elimina, incluidos los respaldos.	Responsable de privacidad
10	Resumen de medidas de seguridad	Documento que se puede entregar a clientes que lo pidan.	Desarrollo

9. Plan de desarrollo por fases

Fase	Contenido	Puerta de salida
0. Cimientos semanas 1 a 4, en paralelo	Contratar al abogado. Base de pruebas en el servidor (copia de la actual). Registro binario y respaldos cifrados con prueba de restauración. Rotar secretos y desconectar Vercel. Pedir respuesta escrita a ChileCompra. Registrar la marca. Elegir el proveedor de correo.	Respaldo restaurado con éxito en pruebas. Abogado trabajando. Consulta enviada a ChileCompra.
1. Núcleo multi-cliente semanas 2 a 10	Cliente en la sesión (hecho). Cliente en las tablas privadas con llaves por cliente. Capa única de acceso a datos y auditoría automática. Filtrar todas las consultas por grupos (negocios; radar y alertas; etiquetas, favoritos y descartadas; comentarios, historial y puente; actividad y reportes). Bloqueo de módulos internos.	La auditoría automática de consultas queda en cero.
2. Administración y radar compartido semanas 8 a 12	Roles de administrador por cliente y superadmin; límite de 2 usuarios; panel para crear, suspender y fijar vencimientos; «entrar como» con registro. Radar compartido: se baja una vez el universo diario y cada cliente filtra dentro de nuestra base; caché de detalles; medición del consumo por origen y por cliente; reducción previa del consumo propio de ICA; cupos de IA y de consultas manuales.	El tercer usuario es rechazado; un cliente nuevo no suma consultas a Mercado Público de forma apreciable.
3. Cumplimiento en el producto semanas 9 a 13	Aceptación de términos con fecha y versión. Centro de privacidad: exportar y borrar datos de una persona o de un cliente. Purga automática y retención. Doble factor para administradores y sesiones más cortas. Bitácora de accesos. Política de cookies publicada. Aviso de la fuente (ChileCompra).	Borrar un cliente de prueba lo elimina completo; la exportación se verifica.
4. Pruebas y seguridad semanas 12 a 15	Pruebas de aislamiento con clientes de prueba en cada despliegue. Prueba de carga que simule 100 clientes. **Prueba de penetración externa.** Simulacro de incidente. Revisión legal final.	**Cero fugas** entre clientes. Hallazgos críticos de la penetración cerrados.

5. Operación comercial semanas 6 a 15, en paralelo	Soporte por ticket, acuerdo de nivel de servicio, facturación y cobro, página de estado, onboarding, landing y demo (ya hechas), contrato y encargo firmados.	Documentos de la sección 8 firmados y publicados.
6. Piloto cerrado semanas 15 a 19	3 a 5 clientes con contrato y precio reducido, con monitoreo diario. Orden de salida: respaldo, migraciones en el servidor, despliegue, clientes.	4 semanas sin incidentes de datos ni de disponibilidad.
7. Lanzamiento y escala	Apertura de la venta con la etapa 1 de infraestructura; revisión mensual de capacidad; pasar a la etapa 2 según las señales definidas.	—

Plazos orientativos para un equipo pequeño; la parte legal y la respuesta de ChileCompra pueden mover las fechas.

---

10. Puertas de salida: no se vende sin esto

1. Contrato de servicio y de encargo de tratamiento **revisados por abogado** y firmados por cada cliente.
2. Política de privacidad y de cookies publicadas; procedimiento de derechos y de incidentes escritos.
3. Pruebas de aislamiento en verde y **cero consultas sin filtro de cliente** en la auditoría automática.
4. Respaldo con recuperación a un punto en el tiempo, **restauración probada**.
5. Prueba de penetración externa realizada y sin hallazgos críticos abiertos.
6. Respuesta escrita de ChileCompra sobre el uso comercial, o una decisión informada del dueño de asumir el riesgo.
7. Doble factor para administradores y secretos rotados.
8. Responsable de privacidad designado y canal de contacto operativo.

---

11. Costos y decisiones

Partidas que hay que presupuestar (sin cifras: se cotizan)

- Abogado de datos personales y contratos (revisión inicial y mantención).
- Prueba de penetración externa, al menos una antes del lanzamiento y luego anual.
- Infraestructura: servidor de base dedicado, almacenamiento de respaldos cifrados, correo transaccional, monitoreo.
- Herramienta de tickets y de página de estado.
- Contador y facturación electrónica; registro de marca.
- **Seguro de responsabilidad civil y de ciberriesgo**, a evaluar con un corredor.

Decisiones que necesitamos de ti

1. Aprobar la **base compartida con cliente_id** (sección 2), con aislamiento bajo demanda.
2. Contratar al abogado de datos personales ahora (Fase 0).
3. Quién será el **responsable de privacidad** y desde qué correo se atenderán los derechos de las personas.
4. Quién solicita el ticket de Mercado Público de la empresa y enviar la consulta a ChileCompra.
5. Correo único global por usuario (propuesto); qué ve el cliente en el detalle de una licitación (sin viabilidad, auditor ni compras); cuántas personas de ICA serán superadmin.
6. Precios y planes comerciales (pendiente), incluido el precio y el cupo del módulo de IA a partir del costo medido (USD 0,27 por licitación).
7. Autorizar la **copia de la base de datos en el servidor para pruebas**; los comandos ya están listos y no se ejecutan hasta que apruebes este plan.

Fuentes consultadas

Información verificada el 22 de octubre de 2026 en fuentes secundarias; confirmar en el texto oficial y con el abogado.
Ley 21.719, vigencia, multas y obligaciones: piranirisk.com/es/hub-regulatorio/ley-21719-proteccion-datos-chile-checklist-vigencia · varelaabogados.cl/post/ley-proteccion-datos-personales-chile-21719 · lexalert.cl/recursos/ley-21719-datos-personales.
Proyecto que posterga la ley (boletín 18.623-07): garrigues.com (Chile: el Ejecutivo presenta proyecto para postergar la entrada en vigor) · actualidadjuridica.doe.cl (postergación avanza en el Senado) · blog.nivel4.com/apdp/senado-aplaza-ley-datos-personales.
Ley 21.663: iapp.org (Ley 21.663, por dónde partir) · carey.cl (entrada en vigencia de disposiciones clave) · garrigues.com (nuevas reglas de ciberseguridad).
Transferencias internacionales: minsegpres.gob.cl (Informe 2, Transferencias Internacionales).
API de Mercado Público y condiciones de uso: chilecompra.cl/api · chilecompra.cl/terminos-y-condiciones-de-uso.